

Pentest Scan Report

Target: http://testphp.vulnweb.com

Status: completed

Created: 2025-12-18 21:28:32.431399+00:00

Summary

High: 0 Medium: 7 Low: 0

Findings (12)

1. Finding 1

Severity: critical

2. Finding 2

Severity: medium

Evidence:

CSP helps prevent XSS and data injection

3. Finding 3

Severity: medium

Evidence:

Protects against clickjacking

4. Finding 4

Severity: medium

Evidence:

Prevents MIME sniffing

5. Finding 5

Severity: medium

Evidence:

Controls referrer information exposure

6. Finding 6

Severity: medium

Evidence:

Enforces HTTPS for all future requests

7. Finding 7

Severity: critical

Evidence:

Possible SSRF: server attempted internal fetch

8. Finding 8

Severity: critical

Evidence:

Possible SSRF: server attempted internal fetch

9. Finding 9

Severity: critical

Evidence:

Possible SSRF: server attempted internal fetch

10. Finding 10

Severity: critical

Evidence:

Possible SSRF: server attempted internal fetch

11. Finding 11

Severity: medium

Evidence:

HTTP detected on port 80

12. Finding 12

Severity: medium

Evidence:

Discovered endpoint /admin with status 301

Raw Engine Response (truncated)

```
{
  "scan_id": null,
  "mode": "full",
  "results": [
    {
      "type": "basic_info",
      "message": "Unknown vulnerability",
      "severity": "critical",
      "confidence": 0.3342526312065515,
      "payload": null,
      "details": null,
      "explanation": "Impact",
      "cvss_score": 9.0,
      "cvss_vector": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H"
    },
    {
      "type": "missing_security_header",
      "message": "CSP helps prevent XSS and data injection",
      "severity": "medium",
      "confidence": 0.36411610167553243,
      "payload": null,
      "details": "CSP helps prevent XSS and data injection",
      "explanation": "Impact",
      "cvss_score": 5.0,
      "cvss_vector": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N"
    },
    {
      "type": "missing_security_header",
      "message": "Protects against clickjacking",
      "severity": "medium",
      "confidence": 0.3560062502770332,
      "payload": null,
      "details": "Protects against clickjacking",
      "explanation": "Impact",
      "cvss_score": 5.0,
      "cvss_vector": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N"
    },
    {
```

```

    "type": "missing_security_header",
    "message": "Prevents MIME sniffing",
    "severity": "medium",
    "confidence": 0.3560062502770332,
    "payload": null,
    "details": "Prevents MIME sniffing",
    "explanation": "Impact",
    "cvss_score": 5.0,
    "cvss_vector": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N"
  },
  {
    "type": "missing_security_header",
    "message": "Controls referrer information exposure",
    "severity": "medium",
    "confidence": 0.3560062502770332,
    "payload": null,
    "details": "Controls referrer information exposure",
    "explanation": "Impact",
    "cvss_score": 5.0,
    "cvss_vector": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N"
  },
  {
    "type": "missing_security_header",
    "message": "Enforces HTTPS for all future requests",
    "severity": "medium",
    "confidence": 0.394125451373312,
    "payload": null,
    "details": "Enforces HTTPS for all future requests",
    "explanation": "Impact",
    "cvss_score": 5.0,
    "cvss_vector": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N"
  },
  {
    "type": "ssrf",
    "message": "SSRF vulnerability detected",
    "severity": "critical",
    "confidence": 0.3342526312065515,
    "payload": "http://127.0.0.1",
    "details": "Possible SSRF: server attempted internal fetch",
    "signature_id": "SIG-SSRF-001",
    "signature_description": "Server-Side Request Forgery",
    "signature_recommendation": "Block internal address ranges and use network-level egress controls.",
    "autofix_summary": "Block internal IP ranges and use an allowlist for outbound URLs.",
    "autofix_example": "import ipaddress\nfrom urllib.parse import urlparse\n\ndef is_internal(url: str) ->
bool:\n    host = urlparse(url).hostname\n    if not host:\n        return True\n    ip = ipaddress.ip_address
(host)\n    return ip.is_private or ip.is_loopback\n\nif is_internal(user_supplied_url):\n    raise ValueError
('Blocked internal address')",
    "explanation": "Impact",
    "cvss_score": 8.8,

```

```

"cvss_vector": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H"
},
{
  "type": "ssrf",
  "message": "SSRF vulnerability detected",
  "severity": "critical",
  "confidence": 0.3342526312065515,
  "payload": "http://localhost",
  "details": "Possible SSRF: server attempted internal fetch",
  "signature_id": "SIG-SSRF-001",
  "signature_description": "Server-Side Request Forgery",
  "signature_recommendation": "Block internal address ranges and use network-level egress controls.",
  "autofix_summary": "Block internal IP ranges and use an allowlist for outbound URLs.",
  "autofix_example": "import ipaddress\nfrom urllib.parse import urlparse\n\ndef is_internal(url: str) ->
bool:\n host = urlparse(url).hostname\n if not host:\n     return True\n ip = ipaddress.ip_address
(host)\n return ip.is_private or ip.is_loopback\n\nif is_internal(user_supplied_url):\n raise ValueError
('Blocked internal address')",
  "explanation": "Impact",
  "cvss_score": 8.8,
  "cvss_vector": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H"
},
{
  "type": "ssrf",
  "message": "SSRF vulnerability detected",
  "severity": "critical",
  "confidence": 0.3342526312065515,
  "payload": "http://169.254.169.254/latest/meta-data/",
  "details": "Possible SSRF: server attempted internal fetch",
  "signature_id": "SIG-SSRF-001",
  "signature_description": "Server-Side Request Forgery",
  "signature_recommendation": "Block internal address ranges and use network-level egress controls.",
  "autofix_summary": "Block internal IP ranges and use an allowlist for outbound URLs.",
  "autofix_example": "import ipaddress\nfrom urllib.parse import urlparse\n\ndef is_internal(url: str) ->
bool:\n host = urlparse(url).hostname\n if not host:\n     return True\n ip = ipaddress.ip_address
(host)\n return ip.is_private or ip.is_loopback\n\nif is_internal(user_supplied_url):\n raise ValueError
('Blocked internal address')",
  "explanation": "Impact",
  "cvss_score": 8.8,
  "cvss_vector": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H"
},
{
  "type": "ssrf",
  "message": "SSRF vulnerability detected",
  "severity": "critical",
  "confidence": 0.3342526312065515,
  "payload": "http://[::1]",
  "details": "Possible SSRF: server attempted internal fetch",
  "signature_id": "SIG-SSRF-001",
  "signature_description": "Server-Side Request Forgery",

```

```

    "signature_recommendation": "Block internal address ranges and use network-level egress controls.",
    "autofix_summary": "Block internal IP ranges and use an allowlist for outbound URLs.",
    "autofix_example": "import ipaddress\nfrom urllib.parse import urlparse\n\ndef is_internal(url: str) ->
bool:\n    host = urlparse(url).hostname\n    if not host:\n        return True\n    ip = ipaddress.ip_address
(host)\n    return ip.is_private or ip.is_loopback\n\nif is_internal(user_supplied_url):\n    raise ValueError
('Blocked internal address')",
    "explanation": "Impact",
    "cvss_score": 8.8,
    "cvss_vector": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H"
},
{
    "type": "open_port",
    "message": "Open service port detected",
    "severity": "medium",
    "confidence": 0.45674058914850896,
    "payload": null,
    "details": "HTTP detected on port 80",
    "signature_id": "SIG-PORT-001",
    "signature_description": "Open service port",
    "signature_recommendation": "Restrict unnecessary services, enforce network segmentation, and apply fire
wall rules.",
    "explanation": "Impact",
    "cvss_score": 3.0,
    "cvss_vector": "CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N"
},
{
    "type": "endpoint_exposed",
    "message": "Discovered endpoint /admin with status 301",
    "severity": "medium",
    "confidence": 0.3623845058015836,
    "payload": null,
    "details": "Discovered endpoint /admin with status 301",
    "explanation": "Impact",
    "cvss_score": 5.0,
    "cvss_vector": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N"
}
},
"attack_paths": [
    "basic_info -> endpoint_exposed -> ssrf -> missing_security_header -> open_port"
],
"report_path": "reports/report_20251218_162832.pdf"
}

```